

Security+ 1.3 · Change Management

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.3 — Change Management**
(11:22) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Mudança em produção com segurança: documentar a requisição de mudança (RFC), checar risco, aprovar (CAB — Change Advisory Board), testar em ambiente isolado, agendar janela, ter plano de ROLLBACK, avisar afetados; executar, verificar, documentar. Emergency change: menos processo, mas DOCUMENTA depois.

Highlights que a prova cobra

- Rollback plan: o que fazer se der errado — SEM isso, não aprova
- Emergency change: CAB rápido, ainda documentado
- Todo change passa por ambiente de TESTE antes de produção

Dicas de prova & Cenários Típicos

- 'requires rollback plan and testing before deployment' = change management
- 'emergency change bypasses some approvals' = ainda precisa de documentação

Cenário clássico de exame: Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback' → change management.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.3 — Change Management)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. RTO (Recovery Time Objective) mede:

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. ISO/IEC 27001 é:

- A)** A norma INTERNACIONAL de gestão de segurança da informação (SGSI)
- B)** Uma lei dos EUA
- C)** Um tipo de firewall
- D)** Um scanner de vulnerabilidade

4. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Rollback plan: o que fazer se der errado — SEM isso, não aprova'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova...

5. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Emergency change: CAB rápido, ainda documentado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Emergency change: CAB rápido, ainda documentado...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Todo change passa por ambiente de TESTE antes de produção'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Todo change passa por ambiente de TESTE antes de produção...

7. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'requires rollback plan and testing before deployment' = change management'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires rollback plan and testing before deployment' = change management...

8. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'emergency change bypasses some approvals' = ainda precisa de documentação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'emergency change bypasses some approvals' = ainda precisa de documentação...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback' → change management.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário típico: 'aplicação precisa de update no servidor de produção; o téc...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Rollback plan: o que fazer se der errado — SEM isso, não aprova'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Quanto TEMPO o serviço pode ficar fora.

✓ **Por que está certa:** A alternativa correta é: quanto TEMPO o serviço pode ficar fora. O RTO (Recovery Time Objective) é uma métrica central no Plano de Continuidade de Negócios (BCP) e no Plano de Recuperação de Desastres (DRP), abordada no domínio de Continuidade de Negócios e Recuperação de Desastres da CompTIA Security+ SY0-701. Ele define o tempo máximo aceitável para restaurar um serviço ou processo após uma interrupção, antes que o impacto no negócio se torne inaceitável. Por exemplo, se um e-commerce define RTO de 2 horas, a equipe de recuperação deve restabelecer a operação em até 2 horas após o incidente. O RTO orienta a escolha de estratégias de recuperação (hot site, warm site, cold site), a frequência de backups e os investimentos em redundância. Ele é frequentemente confundido com RPO, mas enquanto o RTO mede tempo de inatividade, o RPO mede perda de dados.

✗ **Por que as outras estão erradas:**

- *Quanto DADO você aceita perder:* Essa é a definição de RPO (Recovery Point Objective), não de RTO. O RPO estabelece a quantidade máxima de dados que pode ser perdida, medida em tempo (ex.: 15 minutos de transações). Ele determina a frequência dos backups: se o RPO é de 1 hora, os backups devem ocorrer pelo menos a cada hora. O RTO, por sua vez, foca no tempo de restauração do serviço, não na perda de dados. Confundir os dois conceitos leva a estratégias de recuperação inadequadas, pois um RPO baixo não garante um RTO baixo, e vice-versa.
- *O custo do incidente:* O custo do incidente é uma métrica financeira que quantifica as perdas diretas e indiretas decorrentes de uma interrupção (receita perdida, multas, produtividade, danos à reputação). Embora seja um insumo para justificar investimentos em continuidade, não é a definição de RTO. O RTO é uma meta de tempo, não um valor monetário. Utilizar o custo como definição de RTO desviaria o foco do planejamento de recuperação, que precisa de parâmetros temporais claros para orientar ações técnicas.
- *O número de usuários afetados:* O número de usuários afetados é uma métrica de impacto, útil para priorização e comunicação, mas não define o RTO. O RTO é um objetivo de tempo de recuperação, independentemente da quantidade de usuários. Um serviço crítico para poucos usuários pode ter RTO curto, enquanto um serviço para muitos usuários pode ter RTO mais longo, dependendo da criticidade para o negócio. Portanto, essa alternativa não corresponde ao conceito formal de RTO.

2) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar:* Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção

de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e 'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.

- *Planejar, Fazer, Checar, Agir, Revisar*: Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.

- *Prevenir, Punir, Prever, Provar, Publicar*: Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

3) A — A norma INTERNACIONAL de gestão de segurança da informação (SGSI).

✓ **Por que está certa:** ISO/IEC 27001 é uma norma internacional que especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI). Ela é parte da família ISO/IEC 27000, que aborda práticas de segurança da informação. A norma adota uma abordagem baseada em riscos e é certificável, permitindo que organizações demonstrem conformidade com padrões globais de segurança. É amplamente reconhecida e exigida em contextos de governança, risco e conformidade, sendo um tópico relevante no domínio de Governança, Risco e Conformidade da Security+ (SY0-701), objetivo 5.1.

✗ Por que as outras estão erradas:

- *Uma lei dos EUA*: ISO/IEC 27001 é uma norma internacional desenvolvida pela Organização Internacional para Padronização (ISO) e pela Comissão Eletrotécnica Internacional (IEC), não uma lei. Leis são atos legislativos de um país, como HIPAA ou GLBA nos EUA. A ISO/IEC 27001 é um padrão voluntário que pode ser adotado por organizações em qualquer país, e sua conformidade é atestada por certificação, não por imposição legal. Confundir norma com lei ignora a natureza consensual e global dos padrões ISO.

- *Um tipo de firewall*: ISO/IEC 27001 não é um dispositivo ou software de segurança, mas um conjunto de requisitos de gestão. Firewalls são tecnologias de controle de tráfego de rede, enquanto a ISO/IEC 27001 define processos, políticas e controles para um SGSI. A norma abrange aspectos organizacionais, humanos e técnicos, não se limitando a uma solução técnica específica. Reduzir a norma a um tipo de firewall demonstra incompreensão de seu escopo abrangente e estratégico.

- *Um scanner de vulnerabilidade*: Um scanner de vulnerabilidade é uma ferramenta técnica que identifica falhas em sistemas, redes ou aplicações. A ISO/IEC 27001, por outro lado, é uma norma de gestão que estabelece um framework para governar a segurança da informação como um todo. Embora a norma possa exigir o uso de scanners como parte dos controles, ela não é uma ferramenta. Confundir a norma com um scanner ignora sua natureza de sistema de gestão e seu foco em melhoria contínua e gestão de riscos.

4) D — Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Rollback plan: o que fazer se der errado — SEM isso, não aprova.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Emergency change: CAB rápido, ainda documentado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Emergency change: CAB rápido, ainda documentado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Todo change passa por ambiente de TESTE antes de produção....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Todo change passa por ambiente de TESTE antes de produção.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'requires rollback plan and testing before deployment' = change management....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 1.3 (Change Management): 'requires rollback plan and testing before deployment' = change management.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: 'emergency change bypasses some approvals' = ainda precisa de documentação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): 'emergency change bypasses some approvals' = ainda precisa de documentação.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Cenário típico: 'aplicação precisa de update no servidor de produção; o téc....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback' → change management..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 1.3 (Change Management): Rollback plan: o que fazer se der errado — SEM isso, não aprova.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.